

WEEKLY INTELLIGENCE REPORT

TOP ATTACKS AND BREACHES

- Medtronic, a global medical device maker, has [disclosed](#) a cyberattack on its corporate IT systems. An unauthorized party accessed data, while the company reported no impact on products, operations, or financial systems. Threat group ShinyHunters claimed the theft of 9 million records, and Medtronic is evaluating what data was exposed.
- Vimeo, a global video hosting platform, has [confirmed](#) a data breach stemming from a compromise at analytics vendor Anodot. Exposed data included internal operational information, video titles and metadata, and some customer email addresses, while passwords, payment data, and video content were not accessed.
- Threat actors have [abused](#) the account creation process of the online trading platform Robinhood to launch a phishing campaign that used emails from Robinhood official mailing account. The emails contained links to phishing sites and passed security checks. Robinhood stated that no accounts or funds were compromised and has since removed the vulnerable “Device” field.
- Trellix, a major endpoint security and XDR vendor, was [hit](#) by a source code repository breach after attackers accessed a portion of its internal code. The company engaged forensic experts and law enforcement and claims it has found no evidence of product tampering, pipeline compromise, or active exploitation so far.

AI THREATS

- Researchers [pinpointed](#) CVE-2026-26268, a flaw in Cursor’s coding environment that enables remote code execution when its AI agent interacts with a cloned malicious repository. The attack chains Git hooks and bare repositories to run attacker scripts, risking exposure of source code, tokens, and internal tools.
- Researchers [exposed](#) Bluekit, a phishing-as-a-service platform that bundles 40-plus templates and an AI Assistant using GPT-4.1, Claude, Gemini, Llama, and DeepSeek. The AI-assisted toolkit centralizes domain setup, realistic login clones, anti-analysis filters, real-time session monitoring, and Telegram-based exfiltration.
- Researchers [demonstrated](#) an AI-enabled supply chain attack in which Anthropic’s Claude Opus co-authored a code commit that introduced PromptMink malware into an open-source autonomous crypto trading project. The hidden dependency siphoned credentials, planted persistent SSH access, and stole source code, enabling wallet takeover.

VULNERABILITIES AND PATCHES

- Microsoft has [fixed](#) a privilege escalation flaw in Microsoft Entra ID that allowed the Agent ID Administrator role for AI agents to take over any service account. Researchers published a proof-of-concept showing attackers could add credentials and impersonate privileged identities.
- cPanel has [addressed](#) CVE-2026-41940, a critical authentication bypass in cPanel and WHM that is being actively exploited in the wild as a zero-day, and allows full administrative control without credentials. Patches were issued on April 28, and Shadowserver observed 44,000 internet addresses scanning or attacking decoy systems.

Check Point IPS provides protection against this threat (cPanel Authentication Bypass (CVE-2026-41940))

- Google has [released](#) patches for a critical code execution flaw in the Gemini CLI and its GitHub Action that allowed outsiders to run commands on build servers in CI/CD pipelines. The issue automatically trusted workspace files during automated jobs, allowing malicious pull requests to trigger code execution.
- LiteLLM proxy versions 1.81.16 to 1.83.6 are [affected](#) by CVE-2026-42208, a critical SQL injection flaw used to manage large language model API keys. Attackers can read and potentially alter the proxy database, with exploitation attempts observed about 36 hours after disclosure.

Check Point IPS provides protection against this threat (LiteLLM SQL Injection (CVE-2026-42208))

THREAT INTELLIGENCE REPORTS

- Check Point Research has [revealed](#) that the VECT 2.0 ransomware effectively acts as a data wiper across Windows, Linux, and ESXi. A critical encryption mistake discards required decryption information for files larger than 128 KB, making recovery impossible even after payment.

Check Point Threat Emulation and Harmony Endpoint provide protection against this threat

- Researchers [analyzed](#) a Mirai-based botnet campaign targeting Brazilian internet providers, abusing TP-Link Archer AX21 routers via CVE-2023-1389 and open DNS servers for high-volume amplification attacks. Leaked files linked control activity to infrastructure and SSH keys associated with DDoS mitigation firm Huge Networks.
- Researchers [uncovered](#) a large-scale phishing campaign, dubbed AccountDumpling, that abuses Google AppSheet email services to hijack Facebook accounts. The operation was linked to Vietnam based attackers and is using cloned support pages, reward lures, and live 2FA collection, compromising over 30,000 users and monetizing stolen access through Telegram.
- Researchers [documented](#) a TeamPCP supply chain campaign that compromised four SAP npm packages used in cloud development workflows. The malicious installers harvested developer and cloud credentials across GitHub, npm, and major providers, enabling propagation and downstream compromises before the packages were removed.